

Análisis de Seguridad de túnel público con ngrok

Eddie Santiago Delgado Campo

Sebastian Leiton Goyes

Christian David Home Acero

Docente

Oscar Hernán Mondragón Martínez

Materia

Servicios Telemáticos

Universidad Autónoma de Occidente

Facultad de Ingeniería

Programa de Ingeniería Informática

2026

Análisis de Seguridad – Túnel Público con ngrok

Exponer un servicio local a través de un túnel público como ngrok trae varios riesgos que hay que tener claros antes de dejarlo activo por más tiempo del necesario. El primero es el **aumento de la superficie de exposición**, ya que mientras el túnel esté corriendo, el **servidor Apache** deja de ser accesible solo desde la red privada 192.168.50.0/24 y **pasa a estar disponible para cualquier persona en Internet** que conozca o adivine la URL pública. Esto significa que potencialmente cualquiera que encuentre esa URL puede acceder al servicio y atacar si el servidor está mal configurado.

El segundo riesgo importante es la **ausencia de autenticación**. Tal como se configuró en la Parte 2, el sitio en `/var/www/parcial` es completamente público y no exige usuario ni contraseña para acceder a ningún recurso. Esto no es un problema mientras el contenido sea solo páginas de prueba sin información sensible, pero si **sería crítico si por error se dejará expuesto algún archivo con datos reales, credenciales o configuración interna del servidor**.

Por último están las **limitaciones del plan gratuito de ngrok**, que también implican riesgos operativos:

- La **URL pública cambia cada vez que se reinicia el túnel**, lo que dificulta controlar quién tuvo acceso a una URL anterior.
- **No hay forma de restringir quién puede conectarse**, ya que cualquiera con el enlace entra sin ningún filtro adicional.
- El **ancho de banda y las conexiones simultáneas están limitados**, por lo que un uso indebido (por ejemplo, alguien compartiendo la URL masivamente) podría agotar la cuota y tumbar el túnel

Mitigaciones propuestas

- **Autenticación básica con htpasswd**: Usando el mismo mecanismo que ya se vió en prácticas anteriores (**htpasswd + .htaccess o Directory**), se puede exigir usuario y

contraseña antes de servir cualquier recurso del sitio expuesto. Así, aunque alguien externo descubra la URL pública, no podría ver el contenido sin las credenciales, reduciendo el riesgo de acceso no autorizado.

- **Apagar el túnel inmediatamente después de la prueba:** Como el túnel solo necesita estar activo durante la demostración en vivo, la mitigación más simple y efectiva es **no dejarlo corriendo más tiempo del estrictamente necesario**. Apenas termina la verificación de acceso remoto y el profesor confirma haber visto la página personalizada, se debe cerrar la sesión de ngrok con **Ctrl + C**, eliminando por completo la superficie de la exposición hasta la próxima vez que se necesite.

Como mitigación adicional también podría considerarse la **restricción por IP** a nivel de Apache usando la **directiva Require ip**, limitando el acceso únicamente a la **IP pública desde donde se conectará el profesor** el día de la sustentación, aunque esto requiere conocer esa IP de antemano y es menos práctico que las dos medidas anteriores para un entorno de demostración en vivo donde se accede desde redes distintas (datos móviles, otro WIFI, etc.).